SUPUESTOS Y RESTRICCIONES DE RIESGO TECNOMARKET

1. Propósito

Establecer los supuestos operativos y las restricciones estratégicas que guían la gestión de riesgos en *TecnoMarket S.A. de C.V.*, especialmente en relación con la seguridad de la información, la privacidad de los datos personales y la continuidad de las operaciones digitales.

2. Supuestos de riesgo

- La infraestructura web (Azure) y los servidores on-premise estarán disponibles al menos el **99.5% del tiempo**.
- Los datos personales de empleados y clientes serán tratados conforme a la **LFPDPPP**, con consentimiento informado.
- El equipo técnico interno tiene capacidad suficiente para mantener y evolucionar la plataforma digital.
- Los proveedores externos cumplen con medidas de seguridad equivalentes a las de TecnoMarket.
- Los sistemas críticos tienen copias de seguridad diarias y mecanismos de recuperación probados.
- El Comité de Riesgos se reunirá trimestralmente para revisar el perfil de riesgo y validar decisiones clave.

3. Objetivos de recuperación (RTO / RPO)

Equipos de usuario final (PCs, laptops, móviles)	24 horas	72 horas	Impacto individual, no sistémico

4. Restricciones de riesgo

- No se aceptará ningún riesgo que comprometa la **confidencialidad de datos personales sensibles**, especialmente de salud laboral.
- No se autorizará ningún sistema que carezca de **trazabilidad de accesos y eventos críticos**.
- El CTO, como AO, no podrá actuar como **System Owner ni como proveedor de control común**.
- No se permitirá la operación de sistemas sin **evaluación previa de impacto y categorización formal**.
- No se aceptarán riesgos que puedan generar **interrupciones superiores al RTO definido** por sistema.
- No se transferirá responsabilidad de seguridad a terceros sin contrato formal y cláusulas específicas de protección de datos.
- No se aceptará ningún riesgo que permita la ejecución de **código malicioso sin detección o contención**.
- Se deberán implementar controles específicos contra **ransomware**, incluyendo:
    - Segmentación de red
    - Backups offline
    - Simulacros de recuperación
    - Monitoreo de integridad de archivos
    - Cifrado de datos sensibles

5. Aplicación

Este documento será utilizado por el CTO, el CISO, el DPO y el Comité de Riesgos como referencia para:

- Evaluar riesgos residuales
- Determinar la aceptabilidad de sistemas
- Priorizar controles técnicos y organizativos
- Justificar decisiones de autorización
- Establecer criterios de recuperación y continuidad

6. Amenazas específicas

Se considera como parte del contexto de riesgo la existencia de amenazas específicas como ransomware, phishing, fallas de proveedor, errores humanos y vulnerabilidades en software de terceros. Estas amenazas son relevantes para la definición de controles, la evaluación de impacto y la priorización de activos.

7. Supuestos sobre recursos humanos

Se asume que el personal clave (CTO, CISO, DPO) cuenta con conocimientos técnicos y normativos suficientes para cumplir sus funciones dentro del RMF. Esto incluye familiaridad con marcos como NIST SP 800-37, SP 800-53, ISO/IEC 27001 y la LFPDPPP. Se considera que el equipo técnico tiene experiencia en administración de infraestructura Azure, gestión de bases de datos, seguridad perimetral y respuesta a incidentes. No se requiere certificación formal, pero sí evidencia de competencia operativa